

침해사고 분석보고서

DroidPhish

피싱 메일을 통한 Android APK 설치 및 원격 접속 설정 분석

분석 대상

Android-x86 데이터 이미지 / 사용자 프로필

주요 시점

2024-11-24 17:04~17:14 UTC

주요 증거

Proton Mail DB · Chrome History · APK · 시스템 XML

사건 요약

Android 기기의 Proton Mail 데이터베이스에서 CEO를 사칭한 메일을 확인했다. 수신 헤더에는 2024-11-24 17:04:42 UTC와 emkei.cz 경유 이력이 남아 있으며, Reply-To는 표시 발신자와 다르다. Chrome 다운로드 기록에는 Booking.apk URL이, 기기 파일과 설치 기록에는 동일 이름의 APK 및 com.hostel.mount 패키지가 확인된다.

APK의 SHA-256은 af081cd26474a6071cde7c6d5bd971e61302fb495abcf317b4a7016bdb98eae2다. 시스템 기록상 설치 시각은 17:14:34.099 UTC이고 위험 권한 13개가 허용돼 있다. 디컴파일한 서비스에는 Base64로 인코딩된 접속 목적지 3.121.139.82:10824가 들어 있다. 연결 성공 및 개인정보 유출은 별도 통신 기록으로 검증해야 한다.

핵심 확인 사항

피싱 경로	Proton Mail CEO 사칭 메일 · 17:04:42 UTC [E-01]
다운로드	Booking.apk Chrome History의 외부 URL [E-02]
설치 패키지	com.hostel.mount 17:14:34.099 UTC [E-04]
원격 접속 설정	3.121.139.82:10824 APK 서비스 문자열 디코딩 [E-06]

판단: 메일 수신 → 외부 APK 다운로드 → 설치까지의 연쇄가 서로 다른 저장소에서 확인된다. 수신자가 링크를 누른 순간, 실제 C2 연결 및 자료 유출량은 현재 자료로 확정할 수 없다.

조사 범위와 사건 흐름

이미지의 ext4 파일 시스템에 Android-x86 사용자 데이터가 확인된다. 메일 DB, 브라우저 방문·다운로드 DB, /data/media/0/Download의 APK, 패키지 및 권한 XML, APK 디컴파일 결과를 상호 대조했다. 시각은 각 저장소의 기록 값이며, 사용자 행위의 정확한 시작 시각과는 구분한다.

확인된 사건 순서 (UTC)

17:04:40	발신 측 Date 및 Message-ID 메일 생성·발신 표시 [E-01]
17:04:42	Proton 수신 서버 통과 Received 헤더 [E-01]
시각 미확인	Booking.apk 다운로드 기록 Chrome History [E-02]
17:14:34.099	com.hostel.mount 최초 설치 packages.xml의 it [E-04]
분석 시점	13개 위험 권한 허용 상태 runtime-permissions.xml [E-05]

시각 및 파일 해석

packages.xml의 it=1935f2b00f3은 16진수 밀리초 시각이며 2024-11-24 17:14:34.099 UTC로 변환된다. Chrome의 /storage/emulated/0/Download/Booking.apk는 Android 사용자에게 보이는 경로이며, 이미지 내에서는 /data/media/0/Download/Booking.apk를 조사했다.

마지막 부팅 시각: bootstat의 time_since_last_boot 파일은 비어 있어 이 자료만으로 특정할 수 없다.

피싱 메일과 발신 경로

Proton Mail의 db-mail ConversationEntity에서 제목 "Celebrating 3 Years of Success – Thank You!"를 확인했다. 수신자 randy-ma2@proton.me에게 CEO IE 명의로 전달된 메일이며, MessageBodyEntity 헤더가 발신 경로와 수신 시각을 보완한다.

메일 DB의 의심 항목

테이블(T): ConversationEntity					
모든 열에서 필터링					
	conversationId	order	subject	senders	필터
1	RmSwuxesSIkyT25Gw_Ube21wfgpFhpUKK...	5100237457099	Get started with Proton Mail and ...	[{"address": "no-...	[{"addre
2	z_iU-...	5100237332902	Automated Abuse Detection	[{"address": "no-...	[{"addre
3	o0vKSicWI0WvEs0C7TfVxoNWTmMtR7_BK...	5100237321176	Set up automatic forwarding from ...	[{"address": "no-...	[{"addre
4	yTbSNOTcFiZXXUwqcXwFRXJVjzdGMDs2z...	5100237804592	Please verify your HackerRank account	[{"address": "hackers@hackerrank.com"...	[{"addre
5	KFnGaz0xbDBw0X3brmBY2Gd6hD-...	5100237805407	Randy, your pin is 291009. Please ...	[{"address": "security-...	[{"addre
6	NwteUjOZPm3dBjxx8h7FYIWOJh70la4rX...	5100237806941	Confirm your email address	[{"address": "security-...	[{"addre
7	eTjuMOKI1dK0aessJhL6kHGS678cGmz-...	5100237824443	Please confirm your email	[{"address": "no-...	[{"addre
8	Q4pWWqEmoxnG6ySnokczFF4_xnRj4_198...	5100237853189	409567 is your Instagram code	[{"address": "no-...	[{"addre
9	zeQIbrZH5KzOPM6qBOf6DIRrW88WooQtu...	5100237881294	206478 is je Instagram-code	[{"address": "no-...	[{"addre
10	Ch1Fzvhks02qTQI9hW8rg6pJc2yLIvAl...	5100238070235	754362 is je Instagram-code	[{"address": "no-...	[{"addre
11	HVVB_6VUjM_Wj2-...	5100237949595	Randy, your pin is 008004. Please ...	[{"address": "security-...	[{"addre
12	1odU28zh1Mqo85OocQDbNXkKZLsKMcZ...	5100237947414	Randy, your pin is 723786. Please ...	[{"address": "security-...	[{"addre
13	MiluEZmjmiO2ARzouPDkSGWIyjdMxuSQ...	5100237913831	تأكيد عنوان بريدك الإلكتروني	[{"address": "security-...	[{"addre
14	Vro_MksK6CZekKqYjmwAFvr1XEeD_wvA...	5100237908940	رمز التثبيت الخاص بك هو ...	[{"address": "security-...	[{"addre
15		5100238114128	Celebrating 3 Years of Success - ...	[{"address": "ceo-...	[{"addre

그림 1. ConversationEntity의 마지막 행에 CEO 명의 제목이 나타난다 [E-01].

헤더의 식별 값

MessageBodyEntity 헤더 발췌

From: "CEO IE" <ceo-ie@sircorp.s1r>
Reply-To: s1rx.thgp@gmail.com
Received: from emkei.cz [114.29.236.247]
by mailin045.protonmail.ch
Sun, 24 Nov 2024 17:04:42 +0000 (UTC)
Authentication: spf=none; dkim=none; dmarc=none

그림 2. 표시 발신자와 회신 주소의 불일치, 경유 서버, 수신 시각 [E-01].

emkei.cz 경유, 표시 발신자와 다른 회신 주소, 인증 결과 없음은 사칭 판단을 뒷받침한다. 도메인 모양만으로 다른 메일 전체의 정상성을 확정하지 않는다.

APK 다운로드와 파일 식별

Chrome History의 downloads 테이블에는 Booking.apk의 외부 다운로드 URL이 기록돼 있다. 기기 이미지의 /data/media/0/Download에서 같은 이름의 APK를 확인하고 SHA-256을 산출했다. 파일명만으로 두 기록이 동일 바이트임을 뜻하지 않으므로 URL-대상 경로-파일 해시를 함께 보존한다.

다운로드 기록

History / downloads 및 경로 대응

https://provincial-consecutive-lbs-boots.trycloudflare.com/Booking.apk

Chrome target:

/storage/emulated/0/Download/Booking.apk

Image path: /data/media/0/Download/Booking.apk

그림 3. Chrome 다운로드 기록의 URL과 사용자 경로를 이미지 경로에 대응했다 [E-02].

확보 파일의 SHA-256

```
kali@DESKTOP-GH978HR:/mnt/c/Users/user/Desktop/Pentest/Sherlocks/Easy/DroidPhish/FTK_Export/[root]/android-9.0-r2/data/media/0/Download$ sha256sum Booking.apk
af081cd26474a6071cde7c6d5bd971e61302fb495abcf317b4a7016bdb98eae2 Booking.apk
```

그림 4. Booking.apk에 대한 SHA-256 산출 화면 [E-03].

파일 식별자 [E-03]

af081cd26474a6071cde7c6d5bd971e61302fb495abcf317b4a7016bdb98eae2

URL은 유효 경로, 해시는 확보된 APK 파일의 식별 값이다. 해당 임시 도메인의 현재 운영 상태는 사건 당시 상태를 설명하지 않는다.

설치 흔적과 권한

APK의 AndroidManifest.xml에서 package=com.hostel.mount를 확인했다. /data/system/packages.xml에도 같은 패키지의 설치 항목이 존재하며 installer는 com.google.android.packageinstaller로 기록돼 있다. 이 설치자 값만으로 사용자가 직접 승인했는지는 단정하지 않는다.

매니페스트와 시스템 패키지 기록

```
<?xml version="1.0" encoding="utf-8"?>
<manifest xmlns:android="http://schemas.android.com/apk/res/android"
    android:versionCode="3573638"
    android:versionName="35.73.6.38"
    android:compileSdkVersion="23"
    android:compileSdkVersionCodename="6.0-2438415"
    package="com.hostel.mount"
    platformBuildVersionCode="23"
    platformBuildVersionName="6.0-2438415">
```

그림 5. APK 매니페스트의 패키지명 com.hostel.mount [E-04].

packages.xml 핵심 속성

```
package name="com.hostel.mount"
it="1935f2b00f3" ut="1935f2b00f3"
installer="com.google.android.packageinstaller"
UTC: 2024-11-24 17:14:34.099
```

그림 6. 최초 설치 시간(it)을 UTC로 변환한 결과 [E-04].

허용된 위험 권한 13개 [E-05]

READ_SMS, SEND_SMS, READ_CALL_LOG, CALL_PHONE, READ_CONTACTS, GET_ACCOUNTS, READ_PHONE_STATE, ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION, CAMERA, RECORD_AUDIO, READ_EXTERNAL_STORAGE, WRITE_EXTERNAL_STORAGE

권한이 허용된 사실은 접근 가능성을 뜻한다. 개별 데이터 열람·녹음·전송 실행은 앱 및 네트워크 로그로 확인해야 한다.

원격 접속 설정 분석

디컴파일한 initializeService 클래스에 ClientHost와 ClientPort가 Base64 문자열로 선언돼 있다. 각각 디코딩하면 3.121.139.82와 10824다. 이는 앱이 접속하도록 프로그램된 목적지이며, 기기가 실제 연결했는지는 해당 문자열만으로 증명되지 않는다.

코드와 디코딩

```
public class initializeService extends Service {  
    public static String ClientHost = "My4xMjEuMTM5Ljgy";  
    public static String ClientPort = "MTA4MjQ=";
```

그림 7. initializeService의 ClientHost-ClientPort 문자열 [E-06].

Base64 디코딩 결과

My4xMjEuMTM5Ljgy -> 3.121.139.82
MTA4MjQ= -> 10824
Programmed destination: 3.121.139.82:10824

그림 8. 코드 상의 목적지 설정 값이며 실제 세션 성립 여부와 구분한다 [E-06].

통신 확인 항목

연결 여부	단말·방화벽·프록시의 3.121.139.82:10824 세션 기록
전송 내용	패킷·앱 로그 또는 서버 측 수신 자료와 파일 접근 시각
범위	동일 APK 해시·패키지명·다운로드 URL을 다른 단말에서 대조

영향 평가와 대응

영향 판단

확인	사칭 메일 수신, Booking.apk 다운로드 기록과 파일 확보, com.hostel.mount 설치, 13개 위험 권한 허용.
위험	SMS·연락처·통화·위치·카메라·마이크·저장소 정보에 접근할 수 있는 권한 조합.
미확인	메일 링크 클릭 시각, C2 연결 성립, 정보 유출 범위, 추가 단말의 실제 감염 수.

우선 대응

대상 단말의 네트워크를 격리하고 메일 원본·History DB·APK·설치/권한 XML 및 실행 로그를 보존한다. 조직 단말의 동일 APK 해시와 패키지명을 대조하고, 임시 다운로드 URL 및 3.121.139.82:10824의 접속 기록을 조사한다. 영향 계정의 세션과 자격증명을 점검한 뒤, 검증된 절차로 앱 제거·단말 복구를 진행한다.

증거 목록

E-01	Proton Mail db-mail	제목·송신자·헤더·수신 시각
E-02	Chrome History	다운로드 URL·대상 경로
E-03	Booking.apk	SHA-256 파일 식별
E-04	APK / packages.xml	패키지명·설치 시각
E-05	runtime-permissions.xml	위험 권한 13개 허용
E-06	initializeService	인코딩된 IP·포트